

Electronic Signatures

Iulian Aciobanitei, Phd

Bucharest

2024



- 1 Administrative Info
- 2 ES Context
- 3 Standards and Legislation
- 4 PKI
- 5 Remote QES
- 6 Case Studies for ES and PKI

Schedule

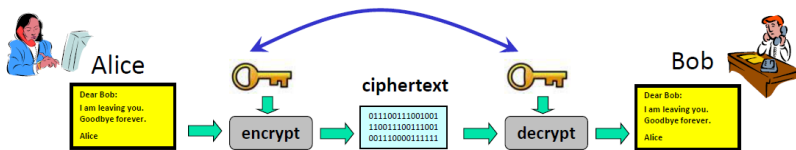
- Day 1: Courses on RSA, EC mathematics
- Day 2: Courses on digital signatures and PKI
- Day 3: Laboratories - working with signatures
- Day 4: Courses on Remote Signatures and other services

Grading

- 1 point ex officio
- 1.5 point from laboratory activity
- 1.5 points from presence
- 6 points exam

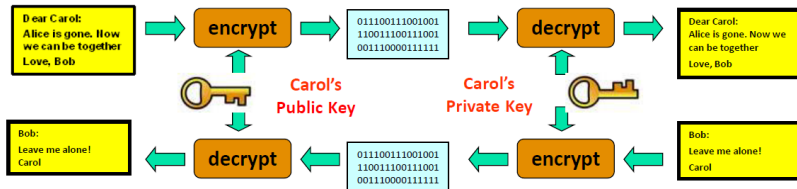
Exam will be a multiple choice test.

Symmetric Key Cryptography



- Computationally fast
- Implies pre-shared keys
- AES
 - Rijndael Algorithm
 - Joan Daemen and Vincent Rijmen
 - 128,192 and 256 bit keys

Asymmetric Key Cryptography



- One **public key** published for all to see
- One **private key** kept secret by the owner
- Unable to derive private key from public key
- Based upon a hard problem:
 - **RSA** - Integer Factorization (large primes)
 - **Diffie-Hellman** - Discrete Logarithms
 - **ECES** - Elliptic Curve Discrete Logarithm

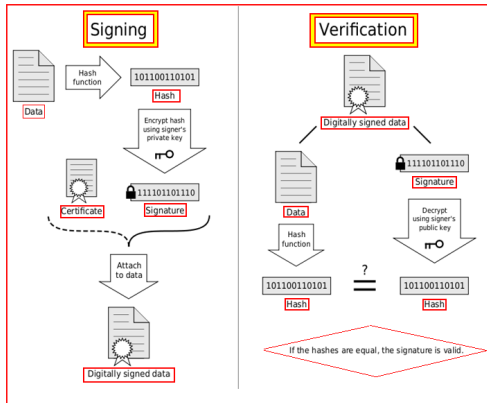
Hash-ing functions

Respect 5 principles:

- **Deterministic:** The same message will produce the same hash value every time.
- **Effective:** It must be quick to compute
- **Irreversible***: It must be infeasible to find a message that produces a specific hash value.
- **No easy collision:** Hard to find two different messages with the same hash value
- *Avalanche*: Any small change in the message shall produce an uncorrelated hash value

*Think like this: You can cook a cow into a burger, but you cannot heal back the burger into a cow.

Digital Signatures - Creation and Verification



Q: What happens if one uses a weak hash function?

Brute Force Against Symmetric Cryptography

- Any cryptographic algorithm can be brute-forced
- The **only defence is a long key**
- Brute force attacks are ideal for parallel processors & distributed computing
- For **every 5 years** in the future, assume the attack is 10 times faster or cheaper.
- Techniques of **differential cryptanalysis** and **linear cryptanalysis** do not present a threat for the use of cryptography, as they are chosen plaintext attacks which require large amounts of plaintext-ciphertext pairs.

Brute Force Against Symmetric Cryptography (cont)

- Average time to break an algorithm with given key length using custom machine costing \$1 million
 - 40 bits 0.2 seconds
 - 56 bits 2.6 hours
 - 64 bits 38 days
 - 80 bits 7.000 years
 - 112 bits 10^{13} years
 - 128 bits 10^{18} years
- In order to break AES 256, it is needed a GPU cluster with consumption of 150 huge nuclear reactors (Kashiwazaki-Kariwa) and all this needs to run way longer than the age of the universe.

Brute Force Against Asymmetric Cryptography

- Public-key crypto (RSA) gets its power from difficulty of factoring large numbers.
- Time taken to brute-force, by key size

512 bits	30.000	mips-years
768 bits	200 mil	mips-years
1024 bits	10^{11}	mips-years
2048 bits	10^{20}	mips-years
- 1 MIPS-Year = $3.1 * 10^{13}$ arithmetic operations (10^6 ops/sec)
- It is an important open problem whether factorization can be done in reasonable time (polynomial time) on a classical computer.
- On a quantum computer, factorization is a tractable problem using Shor's algorithm. Shor's algorithm runs in polynomial time.

Equivalent key sizes for ECC and RSA

NIST guidelines for public key sizes for AES			
ECC KEY SIZE (Bits)	RSA KEY SIZE (Bits)	KEY SIZE RATIO	AES KEY SIZE (Bits)
163	1024	1 : 6	
256	3072	1 : 12	128
384	7680	1 : 20	192
512	15 360	1 : 30	256

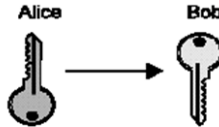
Supplied by NIST to ANSI X9F1

Key Management challenges

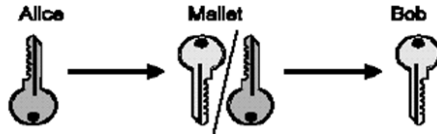
- **Key management is the most difficult part**
- In real life, most attacks succeed not by breaking the algorithm, but by exploiting poor key management
- Main operations related to keys are:
 - Generation
 - Storage & Transfer
 - Usage
 - Update
 - Revocation & Destruction
- Key distribution is the main challenge.

Man-in-the-middle

Alice retains the private key and sends the public key to Bob



Mallet intercepts the key and substitutes his own key

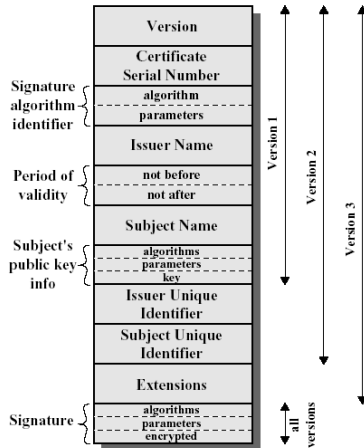


Mallet can decrypt all traffic and generate fake signed message

Asymmetric cryptography problems

- Keys need to be longer in size
- How do you know that the public key you got from a person (entity) really belongs to this person?
 - In other words, subject-public key binding is not assured.
- Solution: **Certificates**, that are like a Driver License or National ID.

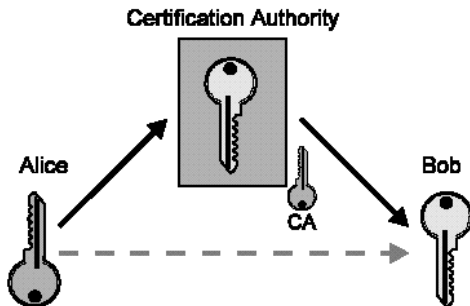
X509 Certificate



(a) X.509 Certificate

PKI

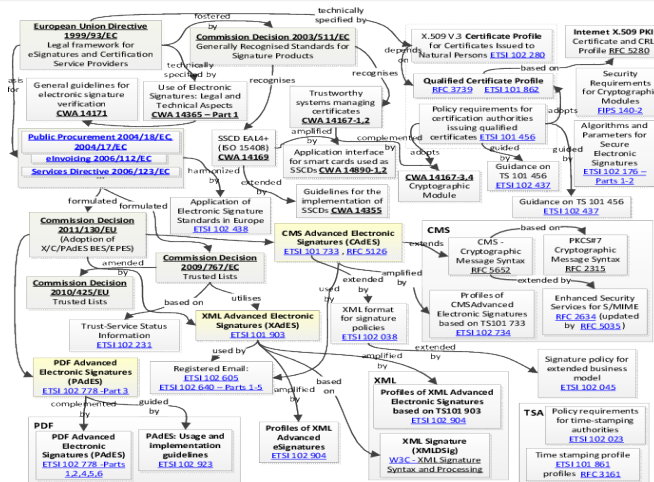
A certification authority (CA) solves this problem



CA signs Alice's key to guarantee its authenticity to Bob

- Mallet can't substitute his key since the CA won't sign it

ES Standards and Legislation



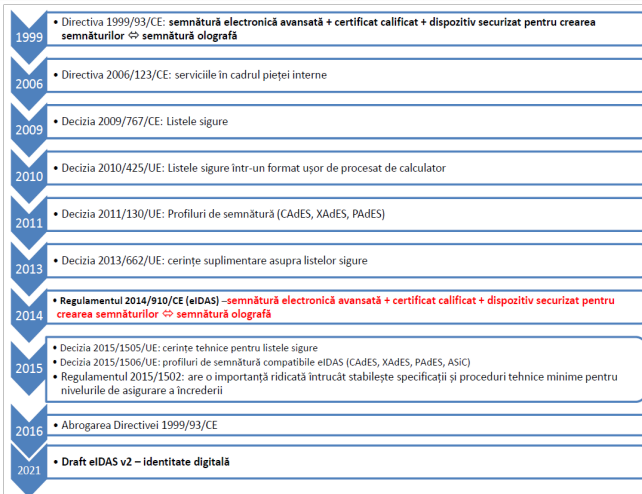
Electronic Signature != Digital Signature

- Electronic Signatures are defined in Global and National Commerce Act (E-Sign Act).
- **Electronic signature** means an electronic **sound, symbol or process**, attached to or logically associated with a contract or other record and executed or adopted by a person with the **intent to sign the record**.
- Electronic signatures implies a proprietary format, since there is no standard for electronic signatures. It can be any digitized information used to identify the author(s), such as: image of an handwritten signature, a symbol, voiceprint, etc.
- Electronic signatures are vulnerable to copying and tampering - forgery becomes easy.
- In many cases, electronic signature validation needs proprietary software.

Electronic Signature != Digital Signature (cont.)

- **Digital Signatures** are a sub group within electronic signatures.
- Also referred to as advanced or standard electronic signature.
- Provides the highest form of signature and content integrity.
 - Is based on **Public Key Infrastructures (PKI)** and
 - Is a result of a **cryptographic operation** that
 - Guarantees signer authenticity, data integrity and non-repudiation of signed documents.
- Digital signatures cannot be copied, tampered or altered.
- Digital signatures made within one application can be validated by others using some other applications.

EU legislation evolution



NIST - Recommendation for the Transitioning of Cryptographic Algorithms and Key Sizes

Table 2: Approval Status of Algorithms Used for Digital Signature Generation and Verification

Digital Signature Process	Domain Parameters	Status
Digital Signature Generation	< 112 bits of security strength: DSA: $(L, N) = (2048, 224), (2048, 256)$ or $(3072, 256)$ ECDSA: $\text{len}(n) < 224$ RSA: $\text{len}(n) < 2048$	Disallowed
	≥ 112 bits of security strength: DSA: $(L, N) = (2048, 224), (2048, 256)$ or $(3072, 256)$ ECDSA or EdDSA: $\text{len}(n) \geq 224$ RSA: $\text{len}(n) \geq 2048$	Acceptable
Digital Signature Verification	< 112 bits of security strength: DSA³²: $((512 \leq L < 2048)$ or $(160 \leq N < 224))$ ECDSA: $160 \leq \text{len}(n) < 224$ RSA: $1024 \leq \text{len}(n) < 2048$	Legacy use
	≥ 112 bits of security strength: DSA: $(L, N) = (2048, 224), (2048, 256)$ or $(3072, 256)$ ECDSA and EdDSA: $\text{len}(n) \geq 224$ RSA: $\text{len}(n) \geq 2048$	Acceptable

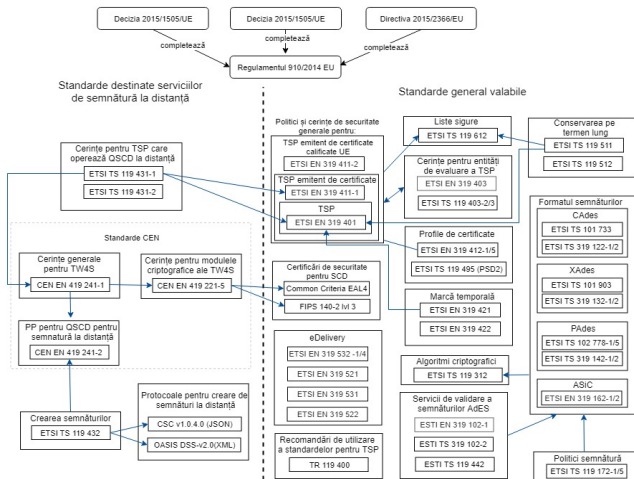
PKCS Standards

- PKCS#1 - std for RSA cryptography
- PKCS#2 - merged in #1. About digest encryption
- PKCS#3 - std for Diffie-Hellman
- PKCS#4 - merged in #1. RSA key format
- PKCS#5 - std for password-based cryptography
- PKCS#6 - std for digital certificate extensions
- PKCS#7 - std cryptographic message syntax

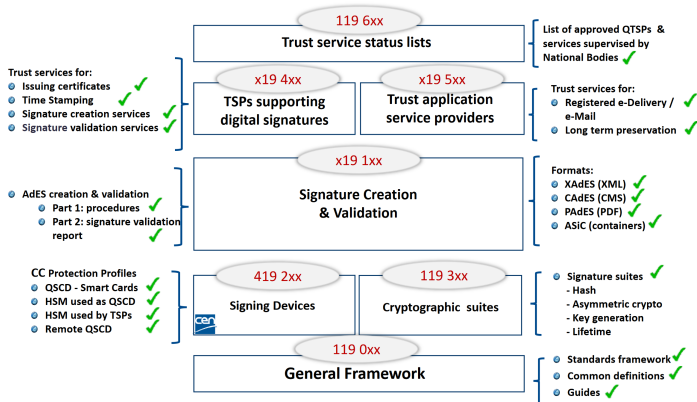
PKCS Standards

- PKCS#8 - std for private key syntax
- PKCS#9 - std for attribute types
- PKCS#10 - std certificate request (CSR) format
- **PKCS#11 - std API for hardware cryptographic devices**
- PKCS#12 - std for software tokens
- PKCS#13 - std for Elliptic Curves cryptography - developing
- PKCS#14 - std for PRNGs - developing
- PKCS#15 - std format for cryptographic tokens

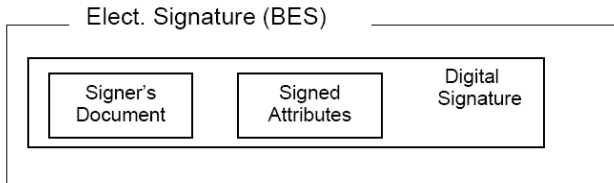
ETSI Standards for RQES



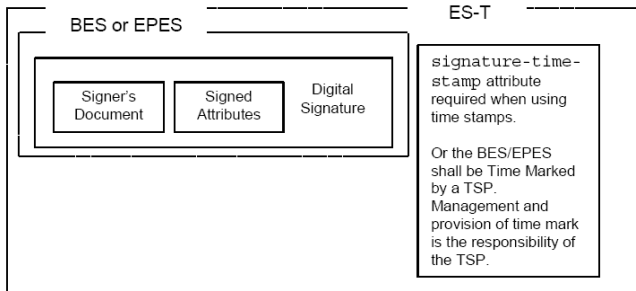
ETSI Standards



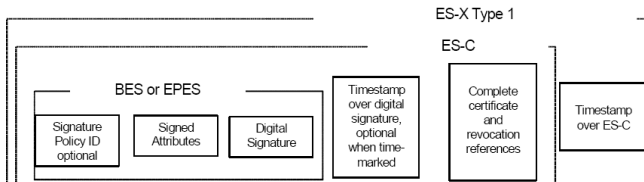
ES Profiles - BES



ES Profiles - BES-T



ES Profiles - LTA



CMS Signatures

- **Definition:** A standard for secure messaging syntax used in cryptographic applications.
- **Key Features:** Supports data encryption and digital signatures.
- **Versatility:** Used for signing, encrypting, and enhancing the security of messages.
- **Integration:** Forms the basis of various signature standards, including CAdES.
- **Use Case:** Commonly used in email encryption and signing, as well as in other secure communication protocols.

CAdES Signatures

- **Definition:** An advanced electronic signature standard designed for a variety of digital formats.
- **Based on:** Builds on the PKCS#7/CMS (Cryptographic Message Syntax) standard.
- **Enhancements:** Adds features for long-term validation of signatures.
- **Formats:** Supports a wide range of data formats, not limited to XML or PDF.
- **Use Case:** Versatile for various digital signing needs, including secure email and document signing.

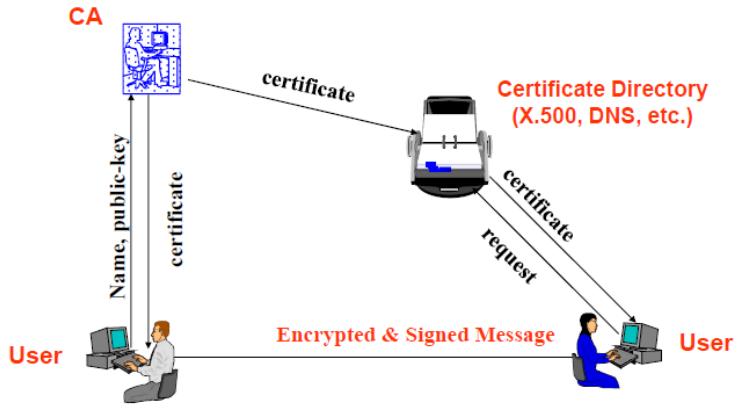
XML(XAdES) Signatures

- **Definition:** A standard for advanced electronic signatures based on XML.
- **Based on:** Extends the CAdES standard, in line with ETSI TS 101 903.
- **Main feature:** Integrates signatures into any XML document.
- **Elements:** Includes signature, timestamp, and certificate information.
- **Use Case:** Suited for Business-to-business applications requiring flexible data structures, such as electronic invoices and governmental documents.

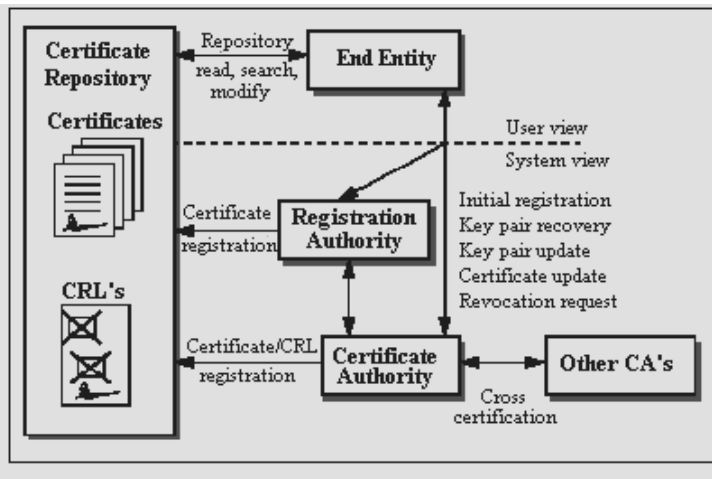
PDF(PAdES) Signatures

- **Definition:** A standard for advanced electronic signatures specifically for the PDF format.
- **Based on:** ETSI TS 102 778; extends the CAdES standard to fit PDF documents.
- **Main feature:** Ensures the authenticity and integrity of PDF documents.
- **Elements:** Includes electronic signature, timestamp, and provision for long-term validation.
- **Use Case:** Ideal for legal and official documents requiring a stable presentation and archiving format.

PKI Overview



PKI Components



PKI End-entity

- Definition: A user of PKI certificate and/or end-user system that is the subject of a certificate
- generic term for subject that uses some PKI services or functions, which may be:
 - a certificate owner - human being, organization, server, etc.
 - a requestor for certificates or CRLs - usually an application.

Certification Authority

CA:

- a trusted authority
- central administration
- provides a statement (the digital certificate) that the enclosed public key belongs to the specified entity:
 - organization/company to its employees
 - university to its students
 - public CAs to their clients

Primary operations of a CA:

- certificate issuance
- certificate renewal
- certificate revocation

Certification Authority (cont)

- Original intent was to certify the binding between the public key with a given entity.
- Role was later expanded to certify all sorts of other things:
 - Are they a bone fide business?
 - Can you trust their web server?
 - Can you trust the code they wrote?
 - Is their account in good standing?
 - Are they over 18?

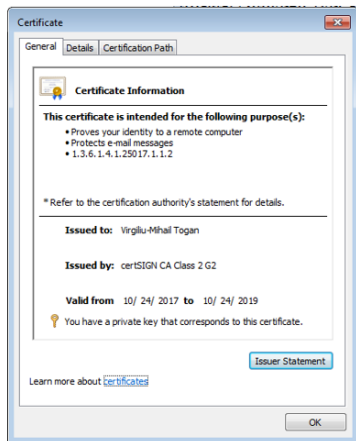
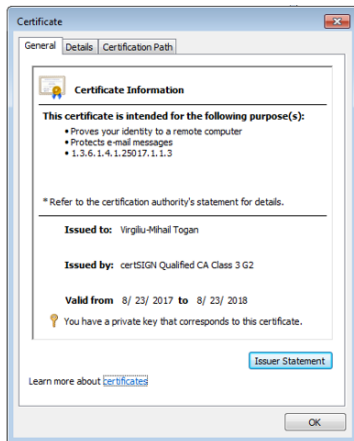
Root CA

- Used to establish TRUST between communities.
- Are installed/configured as **trusted** points.
- Root CA certificates are self-signed.
- Root CA private keys are generated during a key ceremony.
- Root CA is usually kept offline - powered on only when needed.

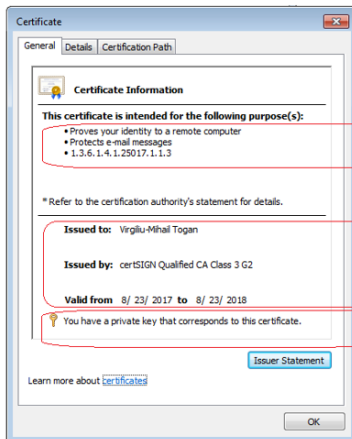
Registration Authority

- Optional component of a PKI
 - The CA can incorporate the role of an RA.
- When used, the RA is:
 - A trusted end-entity certified by the CA
 - acting as a subordinate server of the CA
- The CA can delegate some of its management functions to the RA:
 - personal authentication tasks
 - generate keys
 - archive key pairs
- RA actions have legal implications.
- **The RA does not issue certificates or CRLs.**

Digital Certificates - Widows built-in viewer



Digital Certificates Elements



There are several categories of information:

The main scope of certificate

The SUBJECT of certificate
The ISSUER of certificate
The validity of certificate

If there is a registered private-key, pairing with this public key

Digital Certificates - OIDs

ASN.1 JavaScript decoder

```
SEQUENCE (3 elem)
  SEQUENCE (8 elem)
    [0] (1 elem)
      INTEGER 2
    INTEGER (127 bit) 116562349437600534260500195073713998130
    SEQUENCE (2 elem)
      OBJECT IDENTIFIER 1.2.840.113549.1.1.5
      NULL
    SEQUENCE (4 elem)
      SET (1 elem)
        SEQUENCE (2 elem)
          OBJECT IDENTIFIER 2.5.4.6
          SET (1 elem)
            SET (1 elem)
              SEQUENCE (2 elem)
                OBJECT IDENTIFIER 2.5.4.10
                PrintableString Trans Sped SRL
            SET (1 elem)
              countryName
            SET (1 elem)
              SEQUENCE (2 elem)
                OBJECT IDENTIFIER 2.5.4.11
                PrintableString Trans Sped Certification Authority
            SET (1 elem)
              SEQUENCE (2 elem)
                OBJECT IDENTIFIER 2.5.4.3
                PrintableString Trans Sped QCA
          SEQUENCE (2 elem)
            UTCTime 2015-03-12 00:00:00 UTC
            UTCTime 2016-03-11 23:59:59 UTC
```

Digital Certificates - OID description

OID description

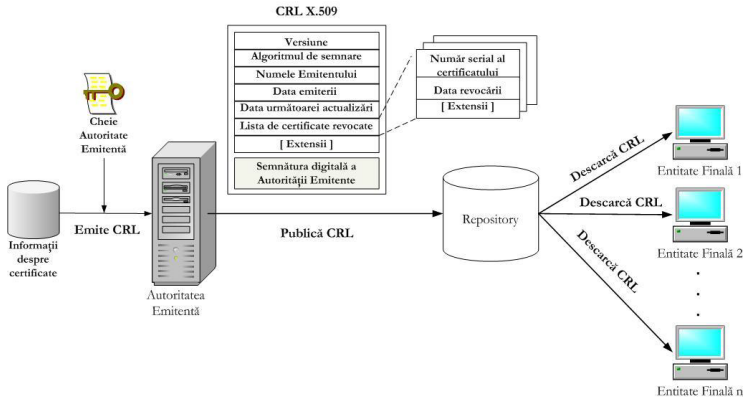
- Format of this page
- Modify this OID
- Create a child OID
- Create a brother
OID
- Find similar OIDs

	{joint-iso-itu-t(2) ds(5) attributeType(4) countryName(6)}	(ASN.1 notation)
OID:	2.5.4.6	(dot notation)
	/Joint-ISO-ITU-T/5/4/6	(<u>OID-IRI</u> notation)
Description: Country name		
Information: This node is defined in <u>Annex A of Rec. ITU-T X.520 (February 2001)</u> and in <u>ISO/IEC 9594-6: 2001</u> : "The Directory: Selected attribute types".		

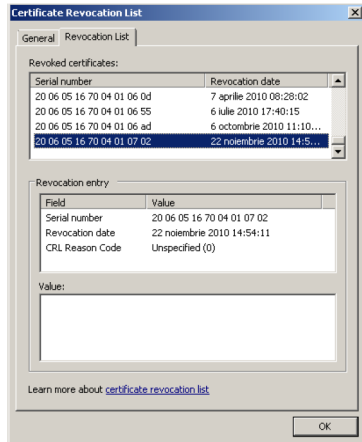
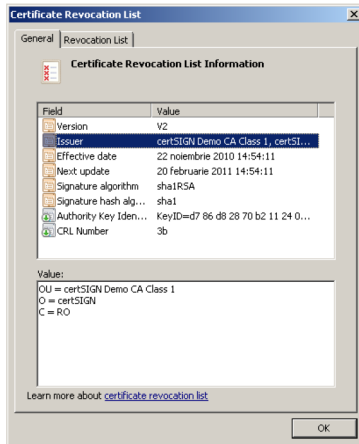
Key usage

- Key usage and enhanced(extended) key usage are some important extensions
- Certificates can only be used for either encryption, or signing.
- What about CSRs?

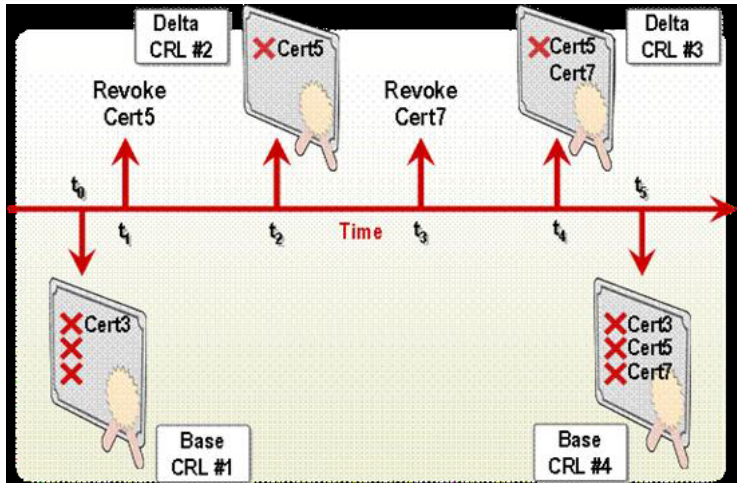
CRL Publishing



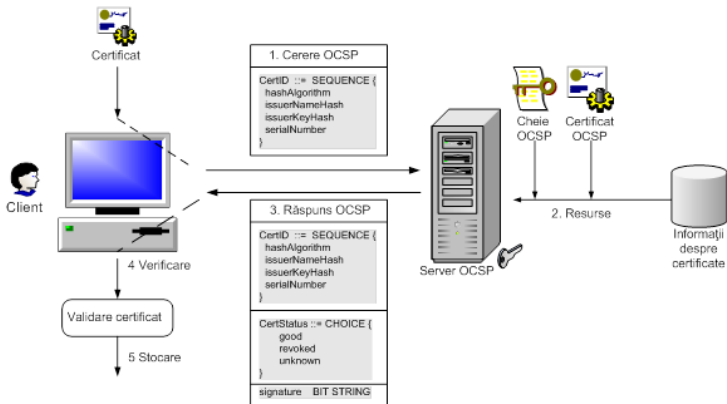
Certificate Revocation Lists (CRL)



Delta CRL



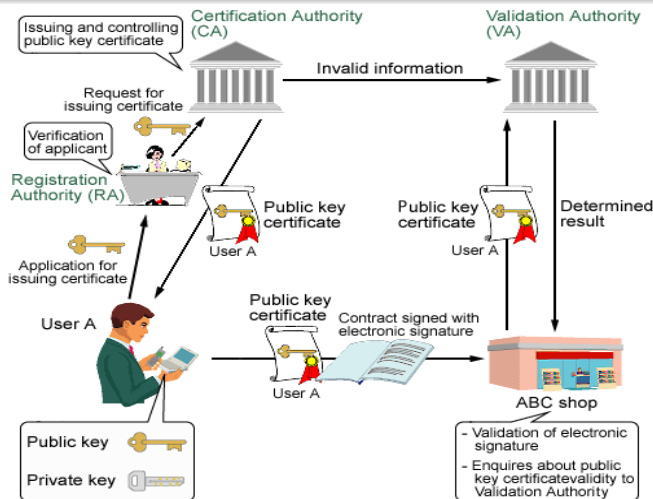
Online Certificate Status Protocol (OCSP)



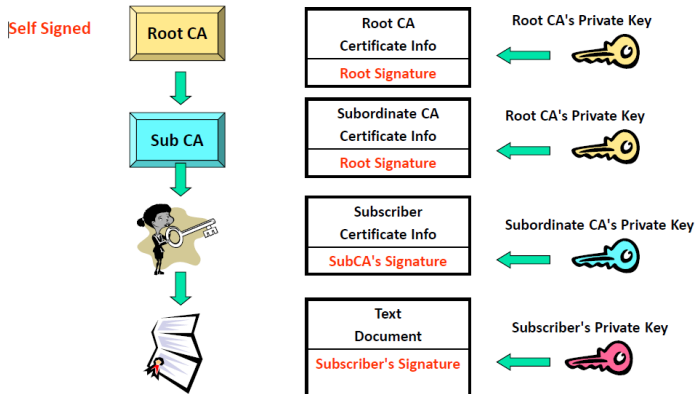
CRL vs. OCSP

- CRL is mandatory, by standards
- OCSP is the more popular
- CRL doesn't offer granularity
- OCSP could offer real time accuracy
- CRL is easier for TSP, more difficult for TPS
- OCSP is the other way around
- OCSP can easily become a single point of failure

Certificate Validation Overview



Certificate Chain



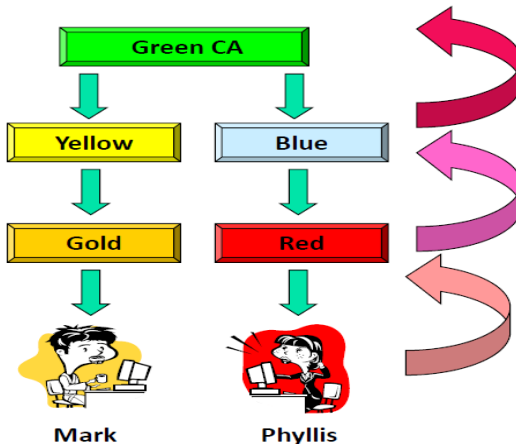
Trust Models

There are many solutions for assuring PKI interoperability:

- Trust Certificate Authority List
- Cross-certification
- Bridge CA
- Delegation of certification path discovery and validation

All of these are called **Trust Models**.

Common trust anchor



Trust Lists

Several such lists are used:

- Microsoft Windows Certificate Store
 - Chrome
 - Edge
- European Trust List (EUTL)
 - Legal Value
 - Human-readable format
 - Computer processable format (ASN.1)
 - History
- Mozilla Certificate Store
 - CABF
- Adobe Approved Trust List (AATL)
 - Contains additional ROOT CAs.
 - For signatures with legal value, Adobe works with EUTL.

Microsoft Store - Trusted Root Certification Authorities

certmgr - [Certificates - Current User\Trusted Root Certification Authorities\Certificates]

File Action View Help

	Issued To	Issued By	Expiration ...	Intended Purpo...	Friendly Name	Stat...	Certificate ...
Certificates - Current User							
Personal							
Trusted Root Certification Authorities							
Certificates	AAA Certificate Services	AAA Certificate Services	1/1/2029	Client Authent...	Secigno (AAA)		
Enterprise Trust	Actalis Authentication Root CA	Actalis Authentication Root...	9/22/2030	Client Authent...	Actalis Authent...		
Intermediate Certification Authorities	AddTrust External CA Root	AddTrust External CA Root	5/30/2020	Client Authent...	Secigno (AddTr...		
Active Directory User Object	Atos TrustedRoot 2011	Atos TrustedRoot 2011	1/1/2031	Client Authent...	Atos TrustedRo...		
Trusted Publishers	Baltimore CyberTrust Root	Baltimore CyberTrust Root	5/13/2025	Client Authent...	DigiCert Baltim...		
Untrusted Certificates	BitDefender Personal CA.Net-Defender	BitDefender Personal CA.N...	4/27/2032	<All>	<None>		
Third-Party Root Certification Authorities	certSIGN ROOT CA	certSIGN ROOT CA	7/4/2031	Client Authent...	certSIGN Root ...		
Certificates	Certum CA	Certum CA	6/11/2027	Client Authent...	Certum		
Trusted People	Certum Trusted Network CA	Certum Trusted Network CA	12/31/2029	Client Authent...	Certum Trusted ...		
Client Authentication Issuers	Class 3 Public Primary Certification Auth...	Class 3 Public Primary Certi...	8/2/2028	Client Authent...	VeriSign Class 3...		
Other People	COMODO RSA Certification Authority	COMODO RSA Certificatio...	1/19/2038	Client Authent...	Secigno (former...		
Local NonRemovable Certificates	Copyright (c) 1997 Microsoft Corp.	Copyright (c) 1997 Microso...	12/31/1999	Time Stamping	Microsoft Time...		
Smart Card Trusted Roots	DigiCert Assured ID Root CA	DigiCert Assured ID Root C...	11/10/2031	<All>	<None>		
	DigiCert Assured ID Root CA	DigiCert Assured ID Root C...	11/10/2031	Client Authent...	DigiCert		
	DigiCert Global Root CA	DigiCert Global Root CA	11/10/2031	Client Authent...	DigiCert		
	DigiCert Global Root G2	DigiCert Global Root G2	1/15/2038	Client Authent...	DigiCert Global...		
	DigiCert Global Root G3	DigiCert Global Root G3	1/15/2038	Client Authent...	DigiCert Global...		
	DigiCert High Assurance EV Root CA	DigiCert High Assurance E...	11/10/2031	<All>	<None>		
	DigiCert High Assurance EV Root CA	DigiCert High Assurance E...	11/10/2031	Client Authent...	DigiCert		
	DigiCert Trusted Root G4	DigiCert Trusted Root G4	1/15/2038	Client Authent...	DigiCert Truste...		
	DST Root CA X3	DST Root CA X3	9/30/2021	Client Authent...	DST Root CA X3		
	Entrust Root Certification Authority	Entrust Root Certification ...	11/27/2026	Client Authent...	Entrust		
	Entrust Root Certification Authority - G2	Entrust Root Certification ...	12/7/2030	Client Authent...	Entrust.net		
	Entrust.net Certification Authority (2048)	Entrust.net Certification Au...	7/24/2029	Client Authent...	Entrust (2048)		
	GlobalSign	GlobalSign	3/18/2029	Client Authent...	GlobalSign Roo...		
	GlobalSign	GlobalSign	12/10/2034	Client Authent...	GlobalSign Roo...		
	GlobalSign Root CA	GlobalSign Root CA	1/28/2028	Client Authent...	GlobalSign Roo...		
	Go Daddy Class 2 Certification Authority	Go Daddy Class 2 Certifica...	6/29/2034	Client Authent...	Go Daddy Class...		
	Go Daddy Root Certificate Authority - G2	Go Daddy Root Certificate ...	1/1/2038	Client Authent...	Go Daddy Root...		
	ISRG Root X1	ISRG Root X1	6/4/2035	Client Authent...	ISRG Root X1		
	localhost	localhost	4/15/2023	Server Authent...	ASP.NET Core ...		
	localhost	localhost	4/16/2027	Server Authent...	IIS Express Dev...		
	Microsoft Authenticode(tm) Root Autho...	Microsoft Authenticode(tm...	1/1/2000	Secure Email, C...	Microsoft Auth...		
	Microsoft ECC Product Root Certificate ...	Microsoft ECC Product Roo...	2/27/2043	<All>	Microsoft ECC ...		

Trusted Root Certification Authorities store contains 57 certificates.

European Trust List - EUTL

Trusted Lists

 Austria Issue date 2022-08-11	...	 Belgium Issue date 2022-09-08	...	 Bulgaria Issue date 2022-06-30	...
 Croatia Issue date 2022-06-15	...	 Cyprus Issue date 2022-09-02	...	 Czech Republic Issue date 2022-10-21	...
 Denmark Issue date 2022-08-16	...	 Estonia Issue date 2022-09-14	...	 Finland Issue date 2022-05-25	...
 France Issue date 2022-10-17	...	 Germany Issue date 2022-10-18	...	 Greece Issue date 2022-09-26	...
 Hungary Issue date 2022-09-16	...	 Iceland Issue date 2022-10-06	...	 Ireland Issue date 2022-10-20	...
 Italy Issue date 2022-07-26	...	 Latvia Issue date 2022-05-24	...	 Liechtenstein Issue date 2022-10-18	...
 Lithuania Issue date 2022-07-01	...	 Luxembourg Issue date 2022-10-10	...	 Malta Issue date 2022-08-25	...
 Netherlands Issue date 2022-06-02	...	 Norway Issue date 2022-06-28	...	 Poland Issue date 2022-09-20	...
 Portugal Issue date 2022-09-12	...	 Romania Issue date 2022-10-19	...	 Slovakia Issue date 2022-10-25	...
 Slovenia Issue date 2022-06-28	...	 Spain Issue date 2022-10-20	...	 Sweden Issue date 2022-10-10	...
 European Union Issue date 2022-10-12	...				

European Trust List - Romanian TSPs

DIGITAL eSignature / eIDAS Dashboard / Browse / Trusted Lists / Romania

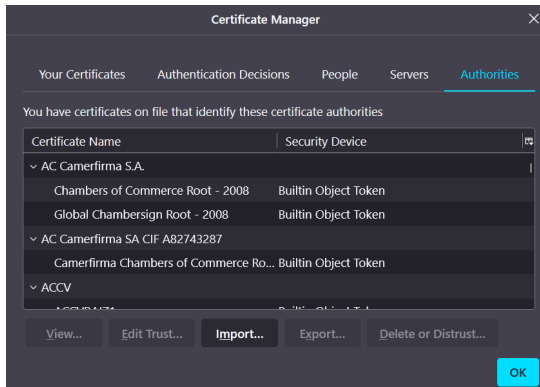
Trusted List Romania

Trust service providers

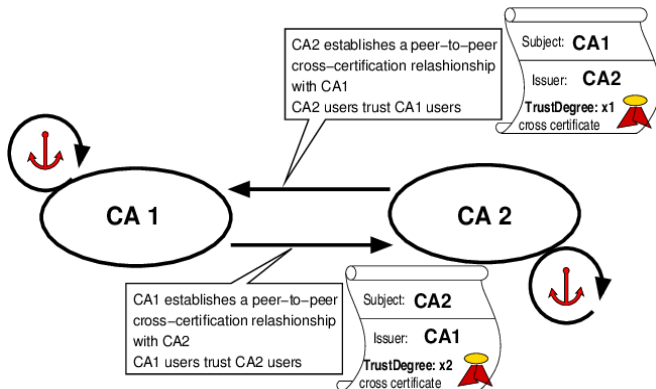
Currently active trust service providers

AlfaTrust Certification S.A. Scan for EIdG Scan for EIdad Certificate Cert for EIdG Timestamp	CENTRUL DE CALCUL SA Scan for EIdG Scan for EIdad Certificate Cert for EIdG Timestamp
CERTSIGN S.A. Scan for EIdG Scan for EIdad Certificate Cert for EIdG Timestamp	DigSign S.A. Scan for EIdG Scan for EIdad Certificate Cert for EIdG Timestamp
Serviciul de Telecomunicatii Speciale Scan for EIdG Scan for EIdad Certificate Cert for EIdG Timestamp	Trans Sped S.A. Scan for EIdG Scan for EIdad Certificate Cert for EIdG Timestamp
ZIPPER SERVICES SRL Certificate	

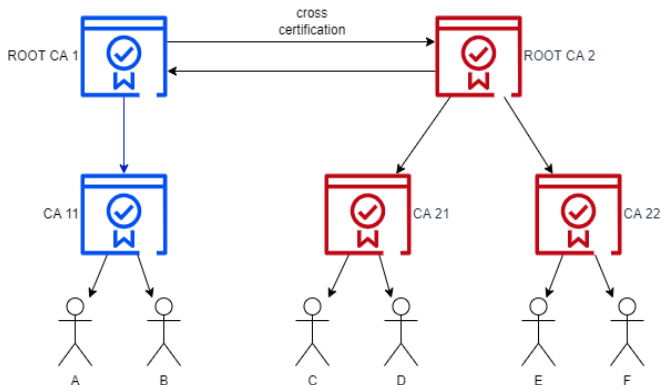
Mozilla Store - Trusted Root Certification Authorities



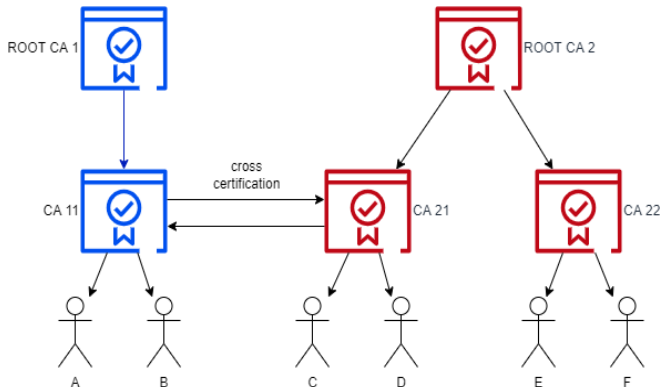
Cross-Certification



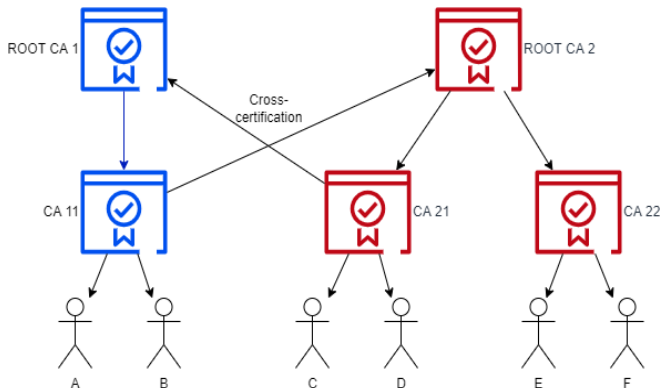
Cross-Certification - RootCA to RootCA



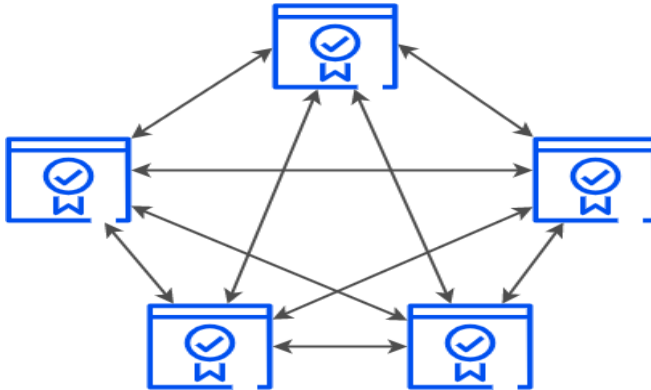
Cross-Certification - SubCA to SubCA



Cross-Certification - SubCA to RootCA

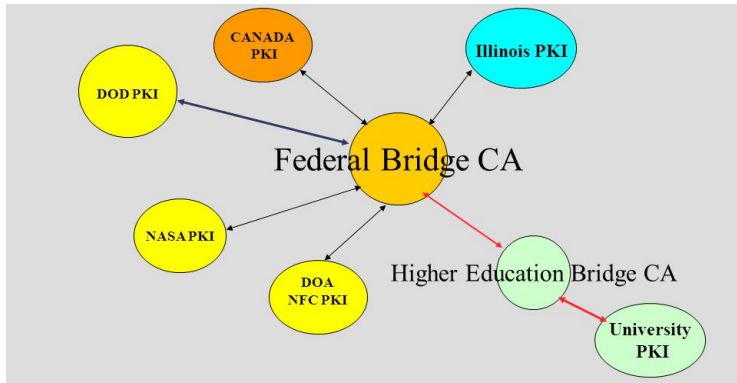


Cross-Certification - Downside



Solution: Bridge CA.

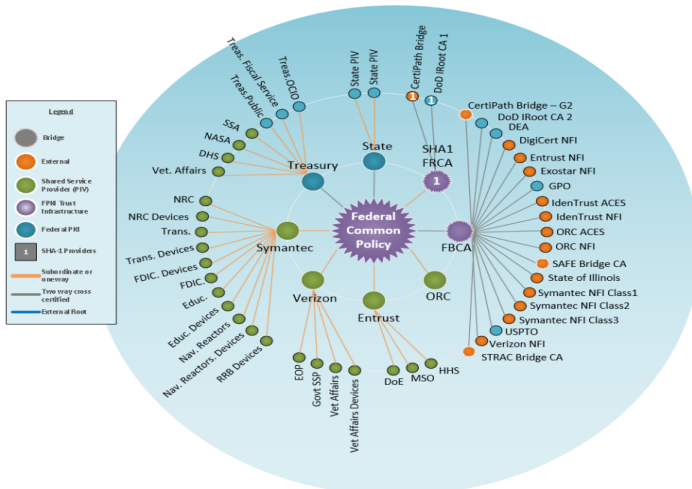
Bridge CA - schema



Administrative Info
ES Context
Standards and Legislation
PKI
Remote QES
Case Studies for ES and PKI

PKI Components
Digital Certificates
Key usage enc vs sign
Certificate Revocation
Certificate Paths
PKI Interoperability
Time-stamping

Bridge CA - Actual look

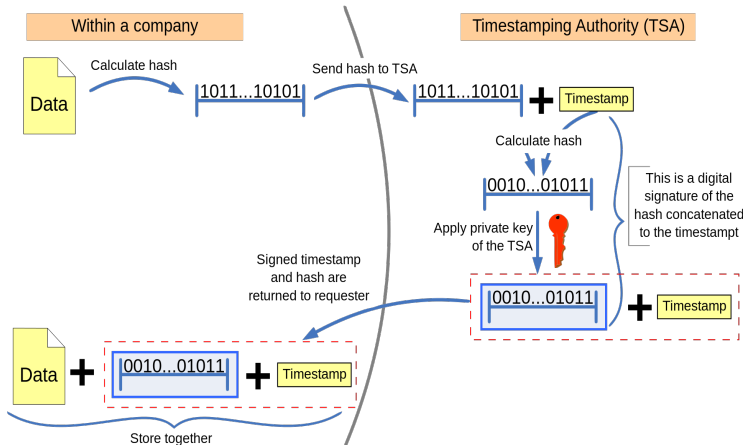


Time-stamping

- A timestamp is used to prove that some datum existed before a particular moment. (signature was generated before a particular time)
- TSP expose timestamp services using a standard protocol, mentioned in RFC 3161.
- TSA (Time Stamping Authority) is the server entity responsible with receiving requests, processing and returning responses.

Obtain a timestamp

Trusted timestamping



Obtain a timestamp for a signature

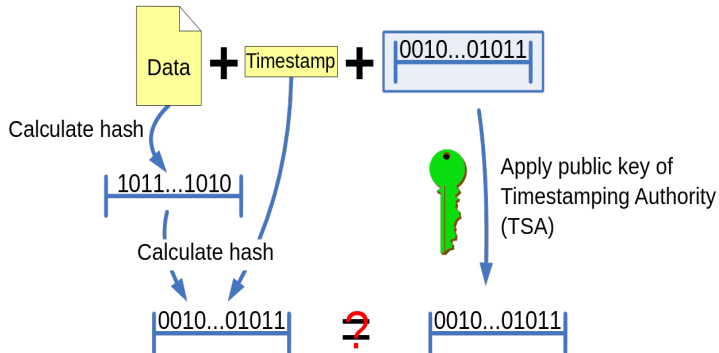
Alice has a document and she wishes to obtain a timestamp so that she can prove that it exists at this point in time:

- Alice digitally signs the document;
- Alice sends the document hash* and the signature to the TSA in a TSP request;
- TSA authenticates Alice;
- TSA generates a signed response to Alice;
- Alice validates the digital signature and stores the response for later use before a legal authority;

*Alice sends the hash of the document, not the whole document.

Check a timestamp

Checking the trusted timestamp



If the calculated hashcode equals the result of the decrypted signature, neither the document or the timestamp was changed and the timestamp was issued by the TTP. If not, either of the previous statements is not true.

Validate a signature with a timestamp

For validating a digital signature (of A) one must:

- Verify the time-stamp generated for this signature (at the creation moment)
- Extract the time of the signature creation, T_g , from the time-stamp.
- Identify and obtain the digital certificate of A
- T_g must be inside the validity period of the digital certificate
- The certificate of A must not be revoked before the T_g moment
- Verifying the signature using the public key of the certificate
- Verify the trust of A's certificate*

Local vs remote signatures

	Local Signature	Cloud Signature
 eIDAS compliant	✓	✓
 U.E. Standards	✓	✓
 Sole Control	✓	✓
 Mobile usage	✗	✓
 No Hardware	✗	✓
 No Drivers	✗	✓
 Reduced costs	✗	✓
 No internet conn	✓	✗

eIDAS - General definitions

- **electronic identification** - the process of using person identification data in electronic form uniquely representing either a natural or legal person;
- **personal identification data** - a set of data enabling the identity of a natural or legal person
- **authentication** - an electronic process that enables the electronic identification of natural or legal person
- **electronic signature** - data in electronic form which is attached to or logically associated with other data in electronic form and which is used by the signatory
- **advanced electronic signatory** - an electronic signature which meets the requirements set out in Article 26

eIDAS - Article 26

An advanced electronic signature shall meet the following requirements:

- (a) it is uniquely linked to the signatory
- (b) it is capable of identifying the signatory
- (c) it is created using electronic signature creation data that the signatory can, with high level of confidence, **use under his sole control**; and
- (d) it is linked to the data signed therewith in such a way that any subsequent change is the data is detectable.

eIDAS - General definitions

- **qualified electronic signature** - an advanced electronic signature created by a qualified electronic signature creation device, and which is based on a qualified certificate for electronic signatures;
- **electronic signature creation data** - unique data which is used by the signatory to create an electronic signature;
- **certificate for electronic signature** - an electronic attestation which links electronic signature validation data to a natural person and confirms at least the name or the pseudonym;
- **qualified certificate for electronic signature** - a certificate for electronic signatures, that is issued by a qualified trust service provider and meets the requirements laid down in Annex I;

eIDAS - Annex I Requirements for qualified certificates for electronic signatures

Qualified certificates for electronic signatures shall contain:

- (a) an indication, at least in a form suitable for automated processing, that the certificate has been issued as a qualified certificate for electronic signature;
- (b) a set of data unambiguously representing the qualified trust service provider issued the qualified certificate including at least, the Member State in which that provider is established and:
 - for a legal person: the name and registration number as stated in the official records
 - for a natural person: the person's name;
- (c) at least the name of the signatory, or a pseudonym; if a pseudonym is used, it shall be clearly indicated;

eIDAS - Annex I Requirements for qualified certificates for electronic signatures (cont)

Qualified certificates for electronic signatures shall contain:

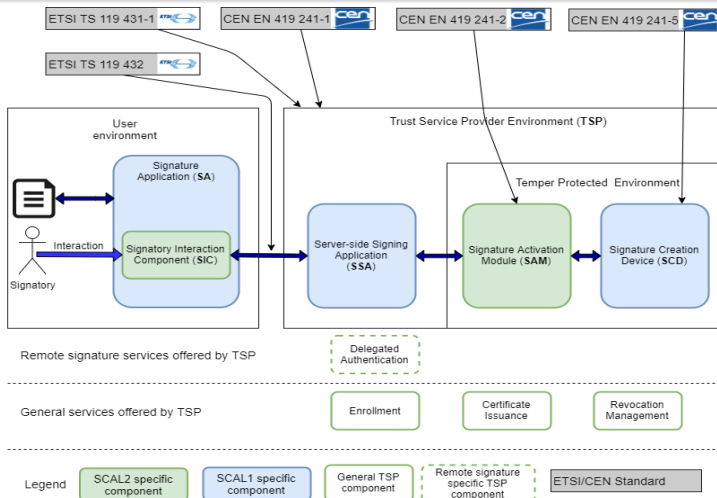
- (d) electronic signature validation data that corresponds to the electronic signature creation data;
- (e) details of the beginning and end of the certificate's period of validity;
- (f) the certificate identity code, which must be unique for the qualified trust service provider;
- (g) the advanced electronic signature or advanced electronic seal of the issuing qualified trust service provider;

eIDAS - Annex I Requirements for qualified certificates for electronic signatures (cont)

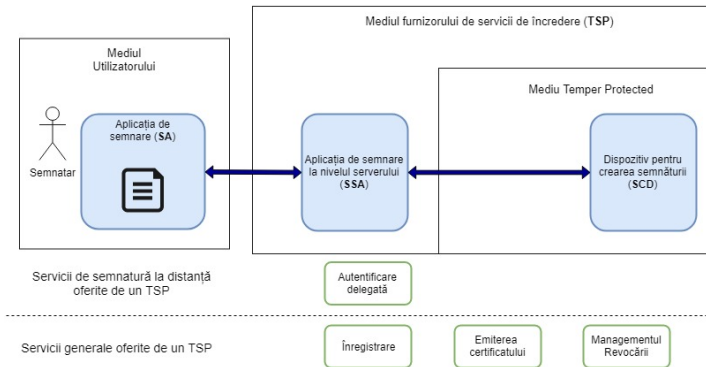
Qualified certificates for electronic signatures shall contain:

- (h) the location where the certificate supporting the advanced electronic signature or advanced electronic seal referred to in point is available free of charge;
- (i) the location of the services that can be used to enquire about the validity status of the qualified certificate;
- (j) where the electronic signature creation data related to the electronic signature validation data is located in a qualified electronic signature creation device, an appropriate indication of this, at least in a form suitable for automated processing.

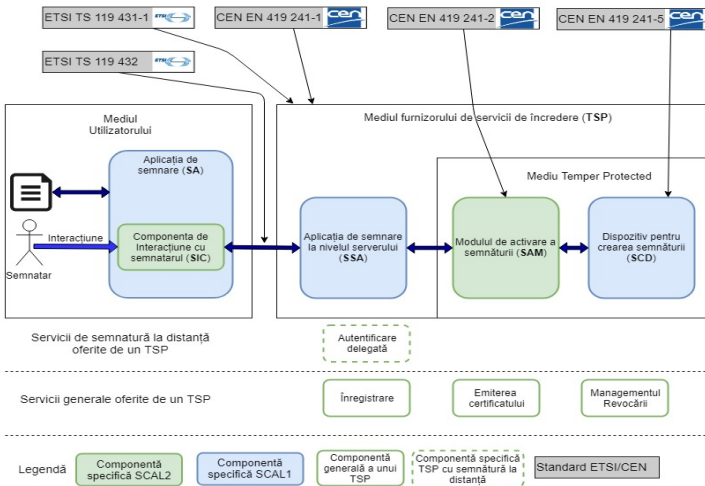
Remote QES Specific Standards



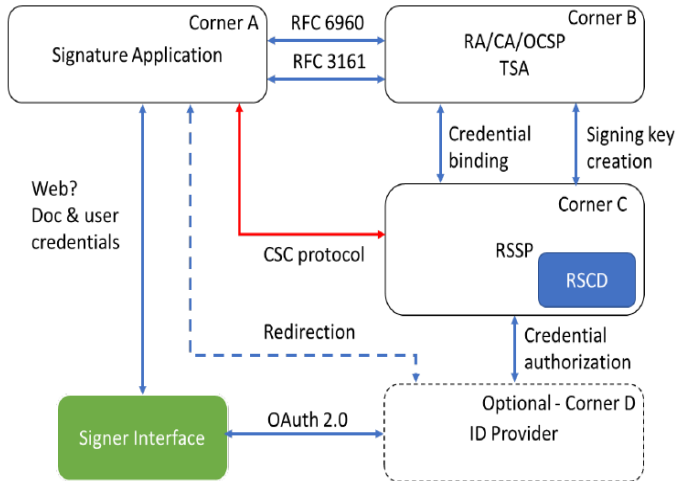
SCAL1 architecture



SCAL2 architecture



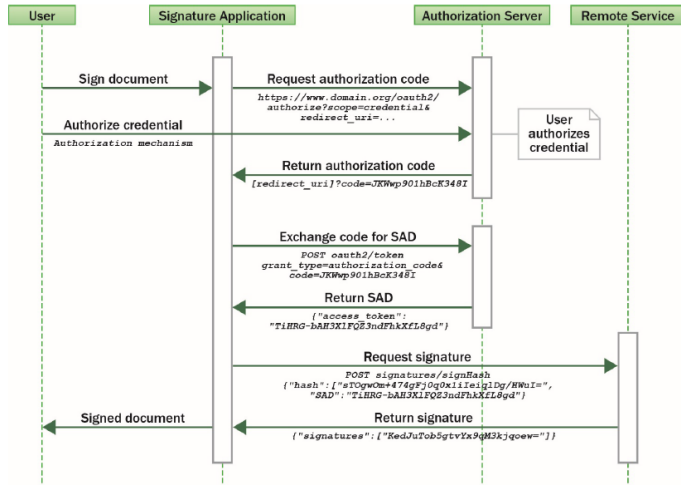
CSC Protocol



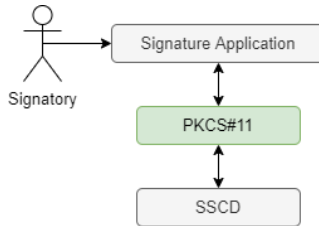
Endpoints

- ① **/info** : Retrieve info about the API
- ② **/credentials/list** : List the credential ids
- ③ **/credentials/info** : Get info about a specific credential (certificate)
- ④ **/credentials/authorize** : Obtain a token be used for authorizing access to the API or to the private key
- ⑤ **/credentials/extendTransaction** : Extend the lifetime of a SAD. Used for user convenience.
- ⑥ **/credentials/sendOTP** : Triggers sending the OTP from server to client
- ⑦ **/credentials/signHash** : Actually signs the hash
- ⑧ **/credentials/timestamp** : Applies a timestamp

Simplified flow

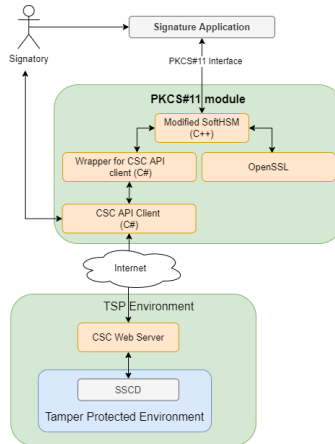


PKCS#11 for local signatures

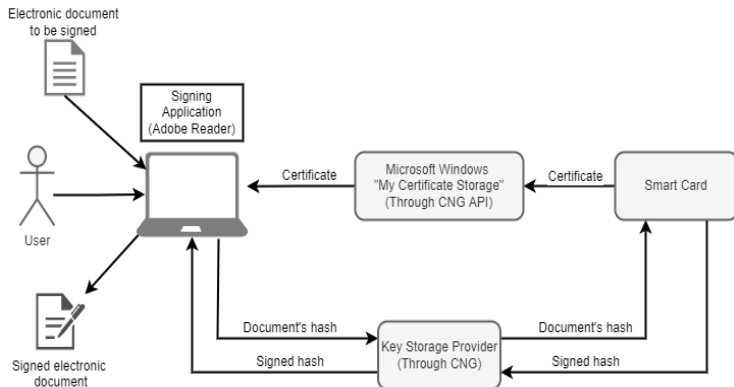


- PKCS#11 driver is a middleware between signature applications and SSCD.

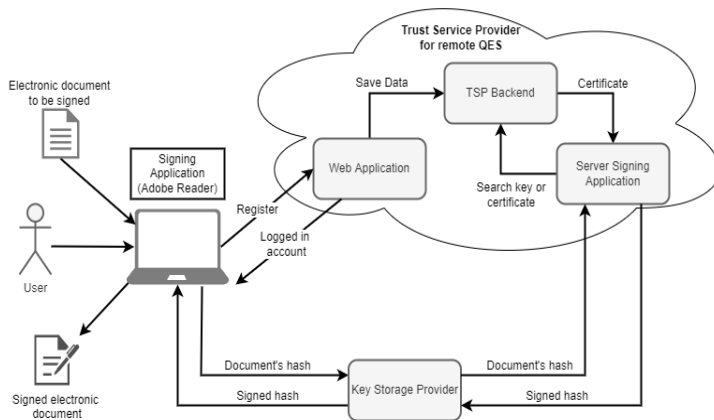
PKCS#11 for cloud signatures



CNG-API for local signatures



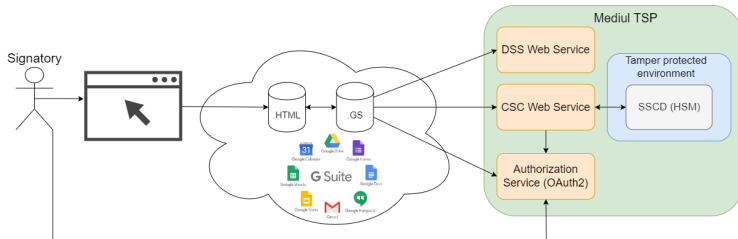
CNG-API for remote signatures



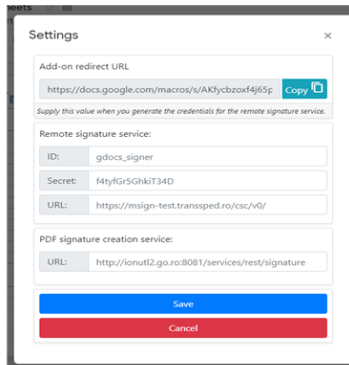
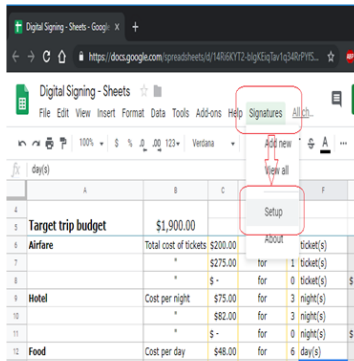
Remote Signatures Applications

- Web Applications
- Native mobile applications
- Bussines-to-Bussines

GSuite Architecture



GSuite GUI



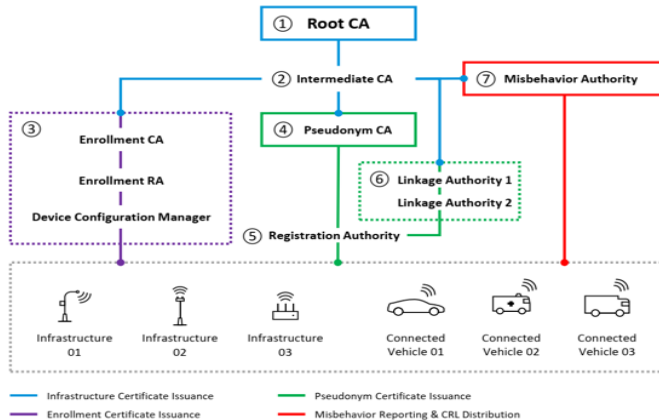
Adobe Sign

- Provide Digital Document Management Features
- Provide ability to sign PDFs
- Ability to add "Fill-in" fields
- Integrates with multiple TSPs via CSC API
- Price per signature
- Demo

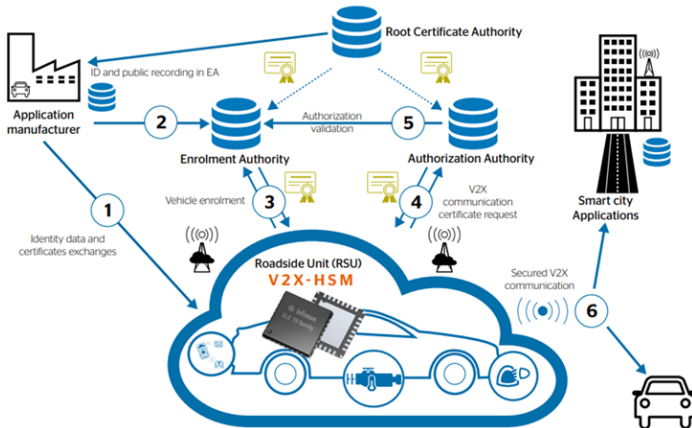
Banking, PKI and TSPs

- Banking started to use digital signatures to improve user experience
- Take advantage of user identification already in place
- Bank employees act as RA agents
- As few steps for the user as possible

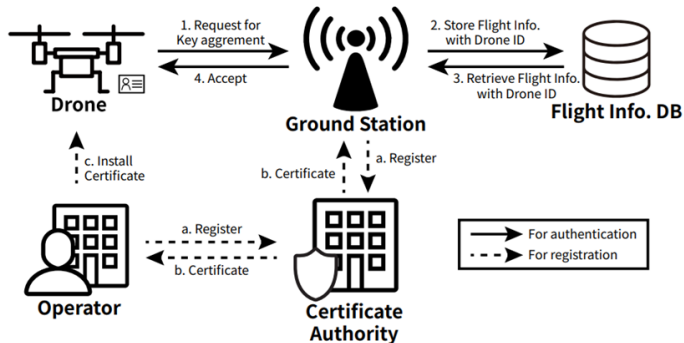
Automotive PKI



AutoCrypt Solution



SENTINEL - drone flights approval



ITS digital certificates

Drone Certificate
Version
Issuer's (CA) Distinguished Name
Validity Period
Subject's Distinguished Name
Subject's Public Key
Issuer's Signature

- ITS use a simplified version of certificates
- More focused on EC cryptography.

What you see is what you sign

- Security relies not only on cryptographic algorithms
- Signature platforms might unintentional or intentional malfunction.
- Risk is amplified since signatures can be performed outside the TSP domain (Adobe Sign)
- Implementations are format specific
 - Only for ASCII strings
 - Only for PDF files
 - etc.
- Cryptomatic offers such a solution

Preservation services

- Main goal: Adapt signatures to signatures providing Long Term Availability and Integrity Material (LTV signatures)
- Regulation 910/2014 (e-IDAS) – Article 34: *Qualified preservation service for qualified electronic signatures*
Qualified trust service that uses procedures and technologies capable of extending the trustworthiness of the qualified electronic signature beyond the technological validity period
- Keeping and guaranteeing the long-term security and availability of electronic signatures in the sense of the e-IDAS Regulation
- The regulation considers this service as an absolutely necessary component in the context of the use of long-term and very long-term signatures

Preservation services - Reasoning

- Security decreases over time due to technological advances and research results
- If at the signing time, all certificates required for validation were valid (not expired) and good (not revoked), the signature must still be successfully validated, regardless of the state of the certificates at the time of validation.
- The information required for validation becomes unavailable over time:
 - Signers' certificates expire in time
 - Signers' certificates might no longer appear in CRLs
 - The CAs no longer provide information regarding PathBuilding, PathValidation and Revocation Validation.

Preservation services - standards

- **ETSI TS 119 511:** Policies and requirements for TSPs to provide LTP trust services
- **ETSI TS 119 512:** Protocol exposed by the TSP for preserving documents. Can be associated with CSC API.

RQES Architecture - A comprehensive approach

